OFFSIDE LABS

# Farming

## Smart Contract Security Assessment

**November 2026**

**Prepared for:**

**Meteora**

**Prepared by:**

**Offside Labs**

*Sirius Xie*



# Contents


**1 About Offside Labs** **2**

**2 Executive Summary** **3**

**3 Summary of Findings** **5**

**4 Key Findings and Recommendations** **6**

4.1 Unfunded Pools Cannot Be Closed . . . . . 6

4.2 Empty User Accounts Can Block Pool Closure . . . . . 7

**5 Disclaimer** **9**

# 1 About Offside Labs

**Offside Labs** is a leading security research team, composed of top talented hackers from both academia and industry.

We possess a wide range of expertise in modern software systems, including, but not limited to, *browsers*, *operating systems*, *IoT devices*, and *hypervisors*. We are also at the forefront of innovative areas like *cryptocurrencies* and *blockchain technologies*. Among our notable accomplishments are remote jailbreaks of devices such as the **iPhone** and **PlayStation 4**, and addressing critical vulnerabilities in the **Tron Network**.

Our team actively engages with and contributes to the security community. Having won and also co-organized *DEFCON CTF*, the most famous CTF competition in the Web2 era, we also triumphed in the **Paradigm CTF 2023** within the Web3 space. In addition, our efforts in responsibly disclosing numerous vulnerabilities to leading tech companies, such as *Apple*, *Google*, and *Microsoft*, have protected digital assets valued at over **$300 million**.

In the transition towards Web3, Offside Labs has achieved remarkable success. We have earned over **$9 million** in bug bounties, and **three** of our innovative techniques were recognized among the **top 10 blockchain hacking techniques of 2022** by the Web3 security community.

 **https://offside.io/**

 **https://github.com/offsidelabs**

 **https://twitter.com/offside_labs**

# 2 Executive Summary

### Introduction

*Offside Labs* completed a security audit of *Meteora Farming* smart contracts, starting on October 21th, 2026, and concluding on October 30th, 2026.

### Project Overview

Meteora Farming is a staking reward program that distributes up to two SPL token rewards in proportion to staked balances over configured reward periods. It operates in a deprecated state, disabling new pools, deposits and reward funding while allowing existing users to withdraw principal, claim accrued rewards and close empty accounts. Pool authorities can recover excess staking tokens and close eligible pools to reclaim remaining rewards and rent.

### Audit Scope

The assessment scope contains mainly the smart contracts of the farming program for the *Meteora Farming* project.

The audit is based on the following specific branches and commit hashes of the codebase repositories:

- Meteora Farming
  - Codebase: `https://github.com/MeteoraAg/reward-pool-internal`
  - PR-3: `PR-3`
  - Commit Hash: 4487e55fb7caabfd34a5c181fbd0f7b138f7af24

The issues described in this report have been resolved by the following commit:

- Meteora Farming
  - Codebase: `https://github.com/MeteoraAg/reward-pool-internal`
  - Commit Hash: 4487e55fb7caabfd34a5c181fbd0f7b138f7af24

We listed the files we have audited below:

- Meteora Farming
  - programs/farming/src/pool.rs
  - programs/farming/src/lib.rs

### Findings

The security audit revealed:

- 0 critical issue
- 0 high issue
- 0 medium issue
- 2 low issues
- 0 informational issue

Further details, including the nature of these issues and recommendations for their remediation, are detailed in the subsequent sections of this report.

# 3 Summary of Findings

| ID | Title | Severity | Status |
|---|---|---|---|
| 01 | Unfunded Pools Cannot Be Closed | Low | Acknowledged |
| 02 | Empty User Accounts Can Block Pool Closure | Low | Acknowledged |

# 4 Key Findings and Recommendations

## 4.1 Unfunded Pools Cannot Be Closed

| Severity: Low | Status: Acknowledged |
| --- | --- |
| Target: Smart Contract | Category: Design |

### Description

Pools are initialized with `reward_duration_end = 0`, which is updated when `fund` IX is called. However, `pause` requires the reward period to have ended and its end timestamp to be nonzero:

```
574 constraint = !pool.paused,
575 constraint = pool.reward_duration_end <
    ↪ Clock::get().unwrap().unix_timestamp.try_into().unwrap(),
576 constraint = pool.reward_duration_end > 0,
```

programs/farming/src/lib.rs#L574-L576

Similarly, `close_pool` IX requires the pool to be paused and enforces the same nonzero timestamp requirement:

```
826 constraint = pool.paused,
827 constraint = pool.reward_duration_end > 0,
828 constraint = pool.reward_duration_end <
    ↪ Clock::get().unwrap().unix_timestamp.try_into().unwrap(),
829 constraint = pool.user_stake_count == 0,
```

programs/farming/src/lib.rs#L826-L829

The deprecation disables `fund` IX, removing the path that could update the timestamp.

Consequently, previously unfunded pools cannot be paused or closed, even after all users withdraw and close their accounts.

### Impact

Affected pools and their vaults cannot be closed under the deprecated program, preventing recovery of their rent deposits.

### Recommendation

It is recommended to allow pools with `reward_duration_end = 0` to pass the reward-period checks in both `pause` and `close_pool`, while retaining the authority, user-count, and empty staking-vault requirements.

### Mitigation Review Log

**Meteora Team**: So far, we haven't had any pool closure cases.

## 4.2 Empty User Accounts Can Block Pool Closure

| Severity: Low | Status: Acknowledged |
| --- | --- |
| Target: Smart Contract | Category: Design |

### Description

The `close_pool` IX requires `user_stake_count` to be zero:

```
829 constraint = pool.user_stake_count == 0,
```

programs/farming/src/lib.rs#L829

This counter tracks existing User accounts and is decremented only by `close_user` IX. Withdrawing all principal and claiming all rewards does not remove the account or decrement the counter.

However, `close_user` IX requires the account owner's signature even when the account has no remaining stake or pending rewards:

```
782 constraint = user.balance_staked == 0,
783 constraint = user.reward_a_per_token_pending == 0,
784 constraint = user.reward_b_per_token_pending == 0,
785 )]
786 user: Account<'info, User>,
787 /// To receive lamports when close the user account
788 #[account(mut)]
789 owner: Signer<'info>,
```

programs/farming/src/lib.rs#L782-L789

Consequently, the pool authority cannot complete pool closure if even one owner leaves an empty User account open.

### Impact

An inactive owner can indefinitely block pool closure, preventing recovery of residual rewards and pool/vault rent deposits through `close_pool` IX.

### Recommendation

It is recommended to allow `permissionless` closure of User accounts with zero stake and zero pending rewards, while preserving the pool and PDA validations and refunding rent

to the recorded owner.

### Mitigation Review Log

**Meteora Team**: So far, we haven't had any pool closure cases.

# 5 Disclaimer

This audit report is provided for informational purposes only and is not intended to be used as investment advice. While we strive to thoroughly review and analyze the smart contracts in question, we must clarify that our services do not encompass an exhaustive security examination. Our audit aims to identify potential security vulnerabilities to the best of our ability, but it does not serve as a guarantee that the smart contracts are completely free from security risks.

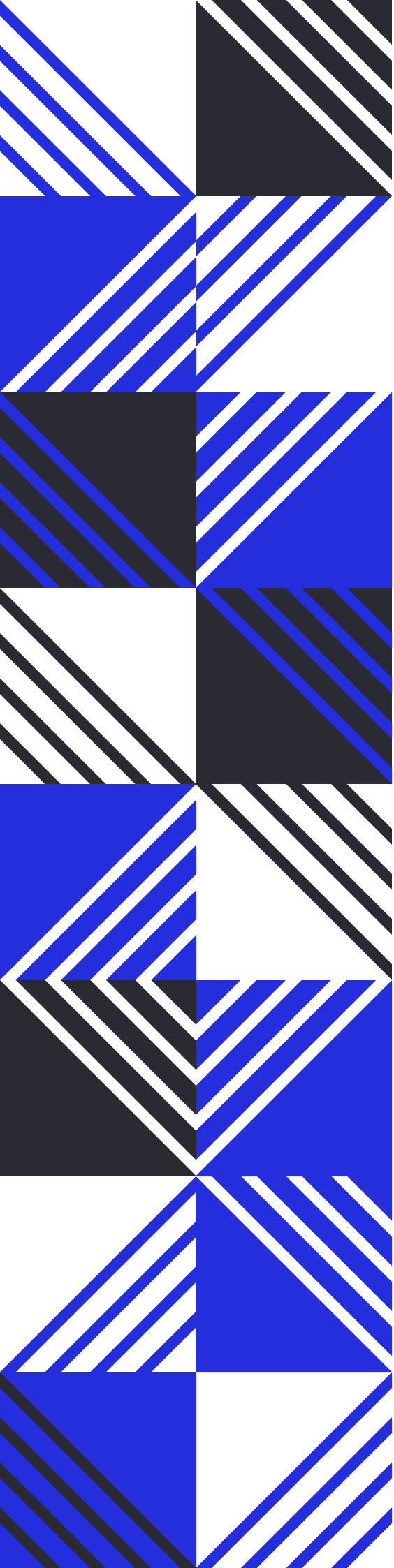
We expressly disclaim any liability for any losses or damages arising from the use of this report or from any security breaches that may occur in the future. We also recommend that our clients engage in multiple independent audits and establish a public bug bounty program as additional measures to bolster the security of their smart contracts.

It is important to note that the scope of our audit is limited to the areas outlined within our engagement and does not include every possible risk or vulnerability. Continuous security practices, including regular audits and monitoring, are essential for maintaining the security of smart contracts over time.

Please note: we are not liable for any security issues stemming from developer errors or misconfigurations at the time of contract deployment; we do not assume responsibility for any centralized governance risks within the project; we are not accountable for any impact on the project's security or availability due to significant damage to the underlying blockchain infrastructure.

By using this report, the client acknowledges the inherent limitations of the audit process and agrees that our firm shall not be held liable for any incidents that may occur subsequent to our engagement.

This report is considered null and void if the report (or any portion thereof) is altered in any manner.



OFFSIDE LABS

https://offside.io/

https://github.com/offsidelabs

https://twitter.com/offside_labs